

# **CyberShield-360 Report**

|                         |                              |
|-------------------------|------------------------------|
| <b>Group Number:</b>    | <b>14</b>                    |
| <b>Group Member(s):</b> | <b>Isaac Martinez</b>        |
| <b>Company</b>          |                              |
| <b>Selection:</b>       | <b>Microsoft Corporation</b> |

## **1. Executive Summary**

*Microsoft Corporation is a global leader in technology, enterprise software, and cloud-based deployments in service of organizations worldwide. The core business component of Microsoft is its Azure cloud ecosystem, which enables scalable, automated, and secure management of sensitive organizational and customer data.*

*The scope of my assessment emphasizes Microsoft's cloud security operations within the Azure ecosystem. With a specific focus on Azure Key Vault, this service eliminates critical attack paths by centralizing secret management, encryption of cryptographic keys and certificate-based identity access.*

*The objective of the assessment is to compare risk methodologies and evaluate how Microsoft's sensitive cloud data is classified, protected, and governed for handling large-scale cloud services. Examining data*

*classification and assessing risk strategies, this analysis imparts insight into Microsoft's strengths and overall cloud security posture.*

## **2. Data Classification and Risk Assessment**

### **2.1. Data Types Identified**

*Microsoft cloud security operations involve managing how sensitive data is stored and protected in Azure Key Vault. The data types of below present categories of cloud data handling by the service.*

#### ***Internal Documentation & Communication:***

*Microsoft exchanges internal business documentation and communications inside managed services: Microsoft 365, Outlook, Teams, SharePoint, in handling non-public information across Microsoft's sectors.*

- *Authentication traceability for managing identity configurations*
- *Audit logs automatically stored inside Azure Active Directory for audit trail integrity*
- *Service-to-service communication authenticated with client certificates*

### ***Customer & Employee Data:***

*Microsoft's processes and logs customer data by account linked service usage aswell as employee PPI, HR records, and Payroll information across Azure hosted enterprise infrastructure.*

- *Securing internal and client web applications/APIs with SSL/TLS for encrypted certificates*
- *Customer-managed services receive keys for encrypting client data at rest in Azure services*
- *Maintaining client encrypted key structure require management within the hierarchy (Key Encrypted Keys)*
- *API keys, Storage account keys, Service credentials, Database connection strings, headers as usernames, passwords, and server addresses*

### ***Financial records & Source code Data:***

*Microsoft manages internal annual fiscal records in SEC filings and revenue metrics. Propriety source code repositories hosted in Azure DevOps and GitHub pipelines.*

- *FIPS 140-2 standards are used for hardware protected keys*
- *Client data exchanged by secured digital signatures and code signing, cryptographic keys leveraged digital signature encryption (SHA-256)*

- *Maintaining software integrity with code signed certificates*

## ***Business Strategy***

*Microsoft's business strategy data leverages stakeholders' communication, merger and acquisitions, intellectual property-patent fillings, and security roadmap implementation.*

- *User identity authorization for secure access to Key Vault resources*
- *Role-Based Access Control establishes governance permission to access keys, secrets, and certificates*

## **2.2. Classification Scheme**

| <i>Tier</i>     | <i>Defined Variables</i>                             | <i>Expected Use</i>                                                                            | <i>Specific Requirements</i>                                                     |
|-----------------|------------------------------------------------------|------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|
| <i>Public</i>   | <i>Can be distributed for public disclosure</i>      | <i>Azure free trial resource, engineering documentation, service descriptions, public APIs</i> | <i>Beyond baseline TLS, intellectual protection only</i>                         |
| <i>Internal</i> | <i>Strictly for internal access, non-public data</i> | <i>Internal email, operation</i>                                                               | <i>Employee credential authenticated; encryption in transit and misuse cases</i> |

|                     |                                                                         |                                                                                                                         |                                                                                                                                                                           |
|---------------------|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                     |                                                                         | <i>procedures, general<br/>business exchange</i>                                                                        |                                                                                                                                                                           |
| <i>Confidential</i> | <i>Sensitive business data<br/>&amp; customer shared<br/>cloud data</i> | <i>Customers data,<br/>annual financial<br/>records, employee<br/>Personally<br/>Identifiable<br/>Information (PII)</i> | <i>Data encrypted at rest and in<br/>transit (TLS/AES-256);<br/>managed by least privilege<br/>access, encryption</i>                                                     |
| <i>Restricted</i>   | <i>Highly risk-sensitive,<br/>highly regulated cloud<br/>data</i>       | <i>Repository source<br/>code, patents,<br/>founding party<br/>/stakeholder<br/>communications</i>                      | <i>Hardware-Backed encryption<br/>offers a physical security<br/>layer mandated by (FIPS<br/>140-2); ensures strict access<br/>control and high-level<br/>monitoring.</i> |

### **2.3. Risk Methodologies Compared**

*Evaluating both assessment methodologies and determining the suitable option for Microsoft-specific cloud-based operations based on NIST Special Publication 800-30 and OCTAVE Allegro.*

**NIST SP 800-53**

*The NIST SP 800-30 is a comprehensive risk framework developed by the National Institute of Standards and Technology. The use of the NIST SP 800-30 method, provides a structured approach for identifying threats, vulnerabilities, and likelihood of potential business impact on complex information systems. This makes a well-suited baseline for an environment dealing with large-scale cloud deployments. Supporting a repeatable risk analysis while integrating technical controls, required governance, and future compliance considerations. Moreover, the disadvantage is the time required to structure documentation and gather organizational resources to create an effective risk assessment.*

### **OCTAVE Allegro**

*OCTAVE Allegro is an asset focused risk methodology that prioritizes risk based on assets information, dependencies, and business impact. Placing less an emphasis on technical controls, and a higher emphasis on identifying qualitative risk evaluations. The process of implementing OCTAVE Allegro requires less implementation and fewer resources making it a much more suitable option for growing and less technically established organizations. However, this approach lacks the technical depth needed for assessing risk inside a complex cloud ecosystem such as Microsoft Azure.*

## **2.4. Chosen Methodology & Justification**

*The assessment methodology recommended is NIST Special Publication 800-30. It is the preferred risk methodology based on various cloud-based operations. Microsoft's cloud-based operations core functions are processing highly sensitive business and client data across worldwide distributions. Requiring strict identity management, encryption, and auditing controls. NIST SP 800-30 offers the depth required to properly evaluate risk posed to cloud assets including system access control mechanisms, and sensitive data protection formatted in a systematic and repeatable manner.*

*OCTAVE Allegro, developed by the Software Engineering Institute at Carnegie Mellon University. Providing an alternative more lightweight method, the NIST 800-30 is better suited for Microsoft's operational complexity and regulatory exposure. In high impact cloud services like Azure, a detailed risk assessment and approach is necessary for effective cloud services security and long-term decision-making.*

### **3.0 Gap Analysis Plan**

#### **NIST SP 800-171**

*The requirements inside NIST SP 800-171 Rev.2 outline 110 system security requirements across fourteen control families, ensuring organizations handling (CUI) Controlled Unclassified Information meet federal mandates. The NIST SP 800-171 is a subset of NIST SP 800-53 designed specifically for organizations*

*operating inside government contracts deals, and on-federal systems holding classified information.*

*Given required controls, this assessment will analyze four families within Appendix D of NIST SP 800-171 Rev.2. The control families selected stem within Microsoft's core business strategy. The most sensitive business assets handled by Microsoft are stakeholder communication, merger and acquisitions activity, which directly support Microsoft's capacity for continued growth in a competitive cloud market. The control safeguard assets through Azure Key Vault, (RBAC) Role Based Access Control, Access, Authentication, Identification and Authorization. These control families protect the most critical assets for CUI handling Microsoft's cloud environment head on.*

*The objective is to outline the current system posture, gaps, dependencies, and structure security planning for Azure Key Vault for Microsoft as a government contractor managing unclassified Information (CUI) under NIST SP 800-171. This document does not certify security preparedness or assess implementation quality.*

### **3.1. Security Objectives**

- *Does Azure Key Vault access control current mechanisms satisfy NIST SP 800-171 AC requirements for CUI access restriction?*



- *Does Azure Key Vault authentication align with NIST SP 800-171 Rev.21A standards for identity verification?*
- *Do Azure Key Vault cryptographic controls meet NIST SP 800-171 Rev.2 SC requirements for encryption at rest and in transit for handling CUI?*
- *Does Azure Key vault satisfy audit logging (NIST SP 800-171 Rev.2 AU) requirement ensuring accountability and traceability?*

### **3.2. Current State Assessment**

*Microsoft's cloud services in scope include Azure Commercial and Azure Government by two accredited third-party organizations, Kratos and Coalfire. Microsoft underwent testing in 2016 which included a comprehensive review over 400 security controls against Microsoft Azure government environment. The success of the joint authorization board created the first baseline for FedRAMP authorization. Furthermore, attesting Microsoft's meets provisions in NIST SP 800-171 for non-federal systems holding CUI. Confirming Azure government maintains sufficient control over the transmission and traceability across global entities. Moreover, the high sensitivity of data exchange poses significant risk to catastrophic consequences if operational functions were to be compromised.*

*Microsoft's NIST 800-171 Compliance structure achieved FedRAMP authorization. Since the control families within NIST SP 800-171 provisions as a direct subset of NIST SP 800-53. The totality of Azure services operates under FedRAMP controls that meet or exceed an NIST SP 800-53 requirements by*

*design. The third-party joint authorization board holds provisional authority over Azure to operate, requiring the strictest FedRAMP tier available. Furthermore, access control is centralized specifically within Azure Key Vault enforcing Azure role-based access control (RBAC) permissions to internal keys, secrets, and certificate exchanges at a granular subscription resource level. Microsoft Active Directory manages authentication by supporting multifactor authentication within managed identity implementations like Microsoft Entra. Cryptography configurations and standards are leveraged in FIPS-140-2, validating hardware security modules for hardware backed key security. Audit logs are captured within Azure Monitor of individual headers and queries are diagnosed inside as your Active Directory diagnostic logs.*

*Microsoft explicitly states that customers are responsible for securing CUI workloads ensuring compliance with NIST 800-171. Microsoft's core business practice is based on their shared responsibility models, between on premises, Software as a Service (SaaS) Platform as a Service (PaaS). The gaps live within client configuration and enforcement across government affiliated contractors hosting servers and services on Microsoft Azure tenants. Microsoft offers a security lens to meet infrastructure compliance requirements, assuring users oversee appropriate measures for handling controlled unclassified information (CUI).*

### **3.2.1 Validation Methodology**

*To properly validate the current security posture of Azure resource environments the assessment will leverage multiple sources of technical evidence. Using Azure Monitor to generate Audit logs and Microsoft Sentinel will be reviewed to verify flow of authentication, Key Vault usage, and access log events. Hardware configuration baselines and certifications will be inventoried using Azure Policy to ensure deployed resources function within compliance of security standards such as role-based access control (RBAC) and encryption requirements. Microsoft Defender for Cloud would be utilized to identify misconfigurations, compliance deviations, and exposed user identities across contractor tenants. These tools provide measurable evidence to establish security controls aligned with NIST SP 800-171.*

### **3.3. Identified Gaps**

- Configuring customer managed controls such as least privilege and separation of duties are inconsistent across government contractor tenants, despite Azure Role Based Access Control (RBAC) offering technical roadmap capabilities.*
- Hardware security modules (HSM) back storage is not a mandated regulation. By default, CUI adjacent keys on software protected tiers doesn't satisfy FIPS 140-2 hardware requirements.*

- *Lack of standardization across contractor environments creates inconsistencies in traceability of AU control requirements under NIST SP 800-171 Rev.2*
- *Review over who holds key vault permissions rely completely on manual customer process leaving no automated access mechanism that's enforced by default. Leaving AC controls unsatisfied.*

### **3.2. Desired State**

*The following security objectives define the security posture required for Azure Environment to handle controlled unclassified information*

*Audit logging Standard: Azure Key Vault monitored audit logs required a minimum retained period of 365 days within Azure Monitor Sentinel to enhance investigation while meeting NIST SP 800-171 AU control requirements.*

*RBAC Compliance Enforcement: Azure contractors make up 95% of Azure tenants that need RBAC standardized templates aligned with NIST SP 800-171 to ensure enforcements of least privilege access.*

### **3.4. Recommendations/Roadmap**

- ***Risk Level: High. – Failure to meet requirements poses risk to cryptographic keys by software vulnerabilities.***

- *Mandate hardware system management backed key (HSM) storage for contractors' tenants holding restricted CUI data.*
  
- ***Risk Level: High. – Uncontrolled privileges increase insider threat attacks***
  - *Require standardized Role Based Access Control (RBAC) control templates in contingency with required NIST SP 800-171 AC controls for government contractor environments, relieving reliance on tenant-by-tenant manual configurations.*
  
- ***Risk Level: High – Lack of audit retention standards across Azure Monitor and Sentinel***
  - *Standardize retention periods limits of audit log reviews within Azure monitor and Microsoft Sentinel to satisfy AU control requirements.*
  
- ***Risk: Medium. – No automated certification reviews over Key Vault access permissions***
  - *Establish clear policies that require recertification reviews periodically of Azure Key Vault access permissions with alerts for inactive and overprivileged identities.*
  
- ***Risk: Medium. – Multifactor authentication is currently not enforced through Azure Active Directory conditional access***

- *Require multifactor (MFA) enforcement through Azure Active Directory conditional access, overseeing identities within Key Vault access. Closing IA control gaps at the authentication level.*

### ***Risk Level Categorization***

| <b><i>Priority Based on Risk</i></b> | <b><i>Action Item</i></b>                                                                              | <b><i>Timeline</i></b> |
|--------------------------------------|--------------------------------------------------------------------------------------------------------|------------------------|
| <b><i>HIGH</i></b>                   | <i>HSM-backed keys require sufficient storage for CUI tenants</i>                                      | <i>0-30 days</i>       |
| <b><i>HIGH</i></b>                   | <i>Standardize and deploy RBAC templates for contractors</i>                                           | <i>0-30 days</i>       |
| <b><i>MEDIUM</i></b>                 | <i>Multifactor authentication (MFA) enforcement with conditional access via Azure Active Directory</i> | <i>30-60 days</i>      |
| <b><i>MEDIUM</i></b>                 | <i>Standardize audit log retention in Azure Monitor</i>                                                | <i>30-60 days</i>      |
| <b><i>MEDIUM</i></b>                 | <i>Maintain Key Vault access integrity through recertification reviews</i>                             | <i>60-90 days</i>      |

## **4. Malware Attack and Breach Response**

### **4.1 Incident Summary**

*In January 2024 Microsoft disclosed a breach it had experienced, a threat actor identified as Midnight Blizzard, also referred as APT29 and NONBELIUM. The group is backed by Russian Foreign Intelligence Service (SVR), known for orchestrating high-profile cyber espionage breaches with the goal of long-term strategic gain, focused on targeting United States government agencies and global technology organizations.*

*Microsoft and third-party security reports reveal that attackers gained initial access through a password spraying attack against legacy test accounts that lacked strong authentication protections.*

### **4.2. Root Cause Analysis**

*The attack succeeded due to Microsoft's weak identity governance and authentication controls of legacy test accounts without strong multifactor authentication. The attackers used a technique of password spraying, attempting password access simultaneously across multiple accounts hoping to successfully guess an employee's credentials without triggering lockout and threshold account mechanism.*

*Once the attackers established an entry point, they leveraged Microsoft Entra ID to escalate privileges and maintain persistence in their access. Reports determined that attackers manipulated account identity configurations to add their own credentials to the compromised accounts. Allowing them to create access tokens to gain Microsoft corporate tenant environments.*

*Furthermore, analysis uncovered attackers interacted with OAuth endpoints using custom POST requests to create authenticated tokens. Demonstrating the advanced understanding of Microsoft cloud authentication system.*

*Escalating further with the access, attackers were able to search through internal corporate emails systems to gather valuable information related to core Microsoft security operations.*

***Factors contributing to attack success:***

- Lack of mandated multifactor authentication (MFA) across all test accounts*
- Absence of monitoring of anomalous and unauthorized authentication attempts*
- Governance inconsistent over non-production and legacy identities*
- Over-permissive identity privileges within Microsoft Entra ID*



*Overall, the attackers obtained valid credentials and successfully escalated privileges allowing them to remain persistent in Microsoft's internal systems.*

#### **4.3. Impact Assessment**

*Though Microsoft reported that customer environments were not directly compromised, the breach created operational and reputational risk for the organization.*

*Attackers persisted in their access to internal corporate mailboxes, allowing Microsoft's senior leadership accounts to be compromised. Additionally, attackers executed permission within Office 365 Exchange, using "full\_access\_as\_app" permission scope. Allowing further access after admin consent was allowed by the corporate email system.*

*This attack demonstrated how identity-based attacks can bypass traditional security controls and hierarchical configurations that may expose sensitive customer and internal communications within cloud hosted environments.*

#### **4.4. Lessons from Similar Incidents**

*In 2023, Hewlett Packard Enterprise (HPE) a technology solutions company that offers IT services across several domains. Experienced a similar attack backed by Russian state threat group Midnight Blizzard. In this instance, attackers gained HPE's internal email environment through a weak legacy*

*system Office 365. In this breach it was revealed that customer personal information had been leaked. The attack style compromised Microsoft's cloud accounts to gain access to internal inboxes of cybersecurity business sectors. Hewlett Packard Enterprises public response in 2024, disclosed the incidents in SEC form 8-K filing and conducted a formal investigation.*

*These incidents demonstrate a primary attack vector within Microsoft Entra ID, authentication tokens, and Active directory as a critical point of protection.*

#### **4.5. Proposed Countermeasures**

*To prevent similar identity-based breaches in the future. Organization holding sensitive information require sever layers of defense:*

*First, the measure requires implementing multifactor authentication (MFA) enforcement across all accounts, including both production and non-production environments.*

*Second, organizations should implement Role-Based Access Controls (RBAC), and separation of duties to limit excessive privileges. Access permission should be controlled and periodically reviewed to reduce risk of privilege escalation.*

*Third, organizations using Microsoft cloud service should define identity governance and lifecycle management by reviewing unnecessary accounts and removing them on a scheduled basis.*

*Finally, centralized monitoring platforms deployed on Microsoft Sentinel and Azure Monitor detect potential spraying attacks, identifying anomaly behavior, and improving threat detection capabilities overall.*

## **5. Threat Modeling Analysis**

### **5.1 System Process Chosen**

*The process selected for threat modeling is Microsoft Azure Key Vault Authentication and Access system. Representing the process of Azure Entra service to authenticate a user or virtual machine attempting access to the environment then Microsoft intro will validate and allow access to the Azure portal, that interacts directly with the as your key vault to manage cryptographic keys and transfer of certificates and secrets.*

*This system was chosen to since it sits at the center of Microsoft cloud, security architecture and plays a critical role in the findings of the report. Azure key vault is the authoritative source that manages certificates and services that are essential across the azure ecosystem. Any compromising of key vault authentication and access results in a cascading effect that expands across tenant resources and as your services. Emphasis off the midnight blizzard breach analyzed in section 4, showing the authentication and identity layer of the exact system.*

*The scope of the threat model focuses on the authentication and distribution of tokens by as your Entra ID to a user or virtual machine attempting to access azure key vault. The five components are the external administrator, the user portal login, Microsoft Entra, Azure key vault, and Azure Monitor.*

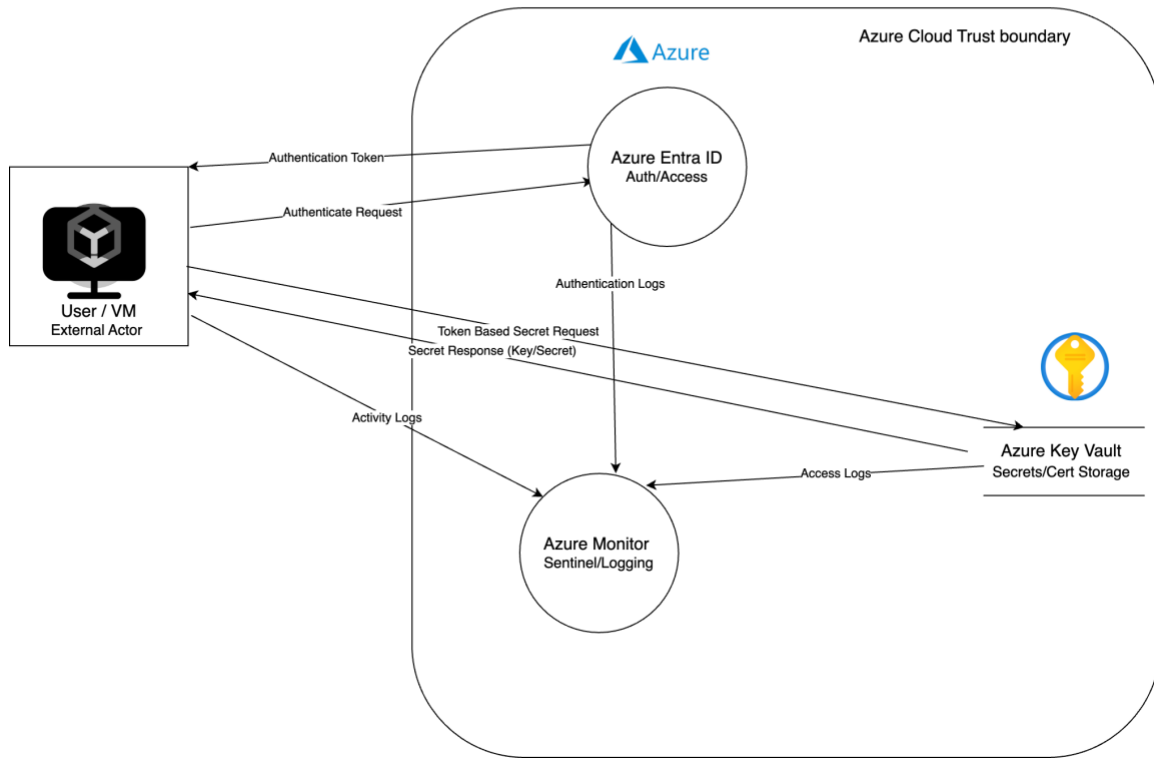
## 5.2 STRIDE Analysis

| <b>Component</b>          | <b>STRIDE Category</b> | <b>Threat Description</b>                                                                                                                                                                                                                                                                             | <b>Suggested mitigation</b>                                                                                     |
|---------------------------|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| <b>API/ Identity Flow</b> | Spoofing (S)           | An attempt to gain unauthorized entry by spoofing client identities and forging new OAuth2 tokens or replaying stolen JWT tokens to access Azure API management. Weak token validation allows an attack to impersonate trusted services and gain unauthorized access to backend logic apps workflows. | Enforce a token validation by implementing conditional access and MFA requirements to verify a user's identity. |
| <b>Azure Key Vault</b>    | Tampering (T)          | In event of an unauthorized identity attempts to modifying, rotate or delete cryptographic key secrets, material, and certificates inside Azure Key Vault. Key Encrypted key                                                                                                                          | Enabling Role Based Access Control (RBAC) with least privileged, using HSM-backed keys for purge                |

|                                |                                   |                                                                                                                                                                                                                                                                    |                                                                                                                                                                      |
|--------------------------------|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                |                                   | <i>(KEK) and Data Encryption key (DEK) disruptions may cause loss of confidentiality and integrity</i>                                                                                                                                                             | <i>protection and enabling soft delete.</i>                                                                                                                          |
| <b>Azure Monitor/Sentinel</b>  | <i>Repudiation (R)</i>            | <i>Attackers aim to deny logs actions causing repudiation, the instance when a user denies actions to remain unnoticed while performing modifications, deleting cryptographic keys, and gaining privileges of compromised accounts through audit manipulation.</i> | <i>Azure Monitor and Sentinel enforce log retention, control remote access to monitor Key Vaults sessions, that should only occur on a private links.</i>            |
| <b>Azure Key Vault</b>         | <i>Information Disclosure (I)</i> | <i>Attacks on Key Vault secrets, keys, or certifications occur due to misconfiguration of policies or compromised user identities.</i>                                                                                                                             | <i>Ensure Azure logging is enabled inside Key Vault, creating a firewall with disabled network access to control the flow of the CUI with only approved parties.</i> |
| <b>API/ Key Vault Endpoint</b> | <i>Denial of Service (D)</i>      | <i>Attackers will flood Key Vault endpoints and authentication</i>                                                                                                                                                                                                 | <i>Filter traffic through Azure Front Door and WAF allowing secure</i>                                                                                               |

|                       |                                    |                                                                                                  |                                                                                                                                            |
|-----------------------|------------------------------------|--------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
|                       |                                    | <i>request to disrupt availability of the services.</i>                                          | <i>API exchanges.<br/>Managed by Azure API management enforcing HTTP as primary forwarding protocol to ensure encrypted API exchanges.</i> |
| <b>Azure Entra ID</b> | <i>Elevation of Privileges (E)</i> | <i>Attackers will escalate privileges to abuse compromised accounts for unauthorized access.</i> | <i>Enforcing RBAC and enabling Privileged Identity Management ensures transparent access reviews.</i>                                      |

Figure x: Data Flow Diagram of Azure Key Vault Authentication and Access System (Yourdon and Coad Symbol)



The data flow diagram of figure above represents Azure key vault access workflow and authentication security using Yourdon and Coad analysis structure.

## User / VM

The first component is an entity living outside the Azure Cloud Trust Boundary, a user or virtual machine initiates authentication request to an Azure Entra ID to access Azure services. Since it is outside of the trust boundary, it's considered an untrusted source, making it the primary point of potential attacks such as spoofing or authorized privilege escalation.



Action:

- Azure Entra ID provides verification of user credentials and issues authentication tokens. When an authorized user submits their credentials Entra ID will then authenticate based on protocols such as OAuth 2.0.

### **Entra ID: Process**

This process enforces, multi factor, authentication, conditional access policies, and token validation mechanisms. Preventing unauthorized access and mitigating spoofing attempts, most critically elevation of privileges.

### **Azure Key Vault: Data Store**

He wants his model as a data store since it stores cryptographic components.

Action:

- API keys/ Secrets
- Encryption
- Digital certificates

Key Vault relies entirely on Entra IDs verification of the user before granting access. Once authentication is successful, unauthorized request will retrieve protected data from the key vault. Making the integrity and confidentiality of this data highly critical. Compromising of this data exposes sensitive information leakage.

### **Azure Monitor / Microsoft Sentinel: Process**

Monitor and sentinel work to log and collect user activity, authentication, and access.

Action:

- Authentication logs required by enter ID
- Access logs sent from key vault
- Activity logs from the user's interactions

The process supports detection of anomalies and ensures accountability to respond to threats such as repudiation and unauthorized activity

### **Data flows:**

The user submits credentials to as Azure Entra ID to authenticate request. Enter ID returns the authentication request to the user creating a token response.

Action:

- Tokens are used to request access to key vault requiring authorized request.
- Key Vault returns requested key to the user, retrieving the secret.
- Entra ID logs to monitor to authenticate logs.
- Key Vault logs access events to Azure Monitor.
- User activity is captured and centrally monitored in activity logs.

### **Trust boundary / Azure Cloud Boundary:**

The diagram is separated by a defined trust boundary representing the secure cloud environment. Components inside this boundary are managed by Microsoft while the external entities operate outside.

The boundary is critical for creating threat models, it showcases where security controls prevent unauthorized access and highlight critical risk where security controls must be enforced. Any data entering this boundary is subject to high risk and requires validation and real time monitoring alerts.

### **5.3 Microsoft Threat Modeling Tool Outputs**

*Due to system incompatibility with the Microsoft threat Modeling tool, the threat modeling was accomplished using OWASP Threat Dragon. An open-source*

*threat modeling platform with Data Flow Diagram creation using standards process, data stores, actors, and external entities.*

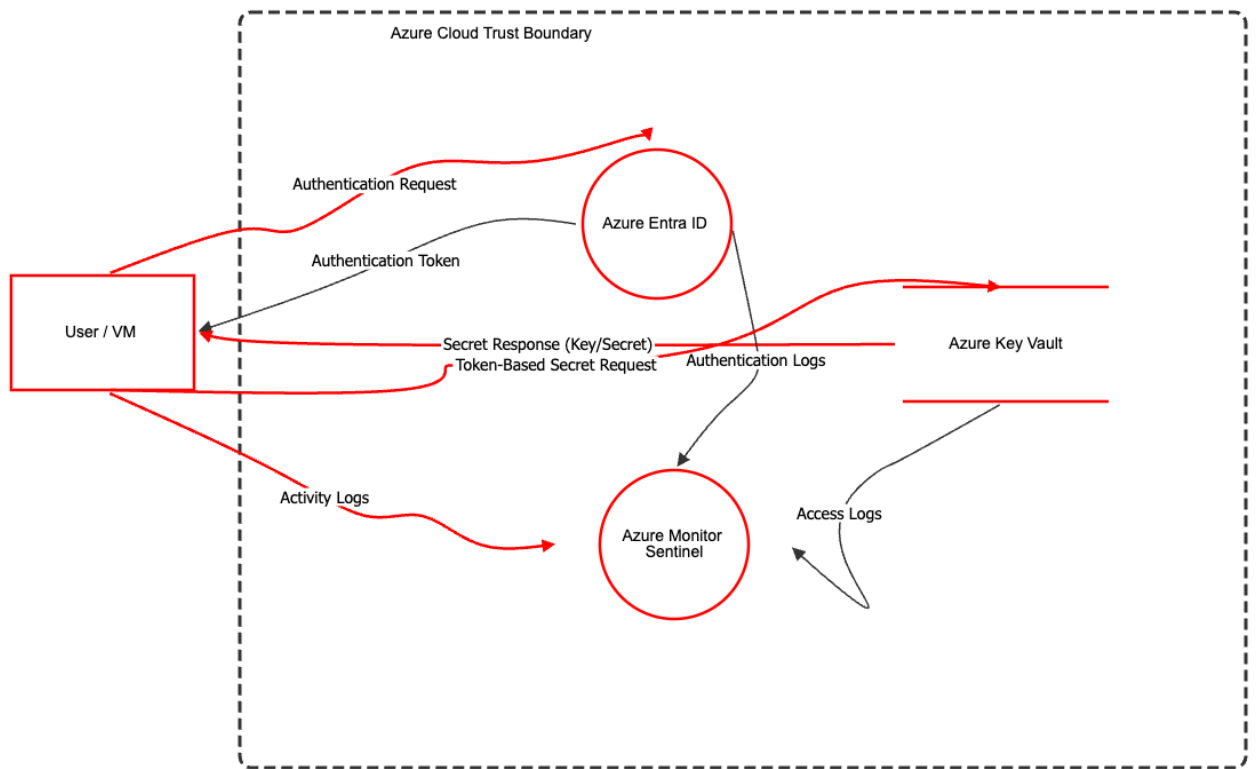
*The tool enables STRIDE framework analyzing system flow description to system threats. The Azure Key Vault authentication workflow was modeled for both components and external entities. In the figure below a user or virtual machine request authentication from Azure Entra ID that is a process to expect and deny tokenized key vault storage, and Azure monitor to log system activity within the defined trust boundary.*

Threat Dragon was used to identify and categorize threats across the 6 STRIDE domains. Furthermore, this modeling system is mature and cannot provide a summarized dashboard of threats and vulnerability ratings. Threats were manually identified and categorized in each threat domain with a detailed description of risk across the data flows and components.

- Spoofing: Identity spoofing during authentication request from user virtual machine to Azure Entra ID.
- Information Disclosure: Information disclosure via Azure key vault exposes transmission of secret on insecure communication channels.

- DDoS: Denial of service can flood Azure key Vault get grant unapproved secret response.
- Tampering: Azure monitor enables control over activity and actions committed inside the system. Sentinel mitigates and verifies audit logs for transparency.
- Repudiation: Attackers will attempt to delete their trace from logging services to refuse fault.
- Elevation of Privileges: when an unprivileged attacker gain access beyond compromised account privilege level. Stemming from misconfigured active directory policies.

Though the Microsoft threat modeling tools generates automated dashboards, OWASP threat dragon contained the appropriate components to create a data flow diagram threat model for as your azure key vault access.



## Threat Results Manual Input:

### STRIDE 6 Manual Domain Threat Results

Title

Privilege Escalation via Misconfigured Roles

Type

Elevation of privilege

Status

High Open Mitigated

Score

Severity

TBD Low Medium High Critical

Description

A compromised identity abuses excessive permissions or misconfigured role-based access control (RBAC) assignments to escalate privileges and gain unauthorized access to Azure resources.

Mitigations

Implement least privilege RBAC, enable Privileged Identity Management (PIM), and conduct periodic access reviews.

Title

Log Data Manipulation

Type

Tampering

Status

High Open Mitigated

Score

Severity

TBD Low Medium High Critical

Description

An attacker may alter, inject, or manipulate activity log data sent from the user or virtual machine to Azure Monitor, compromising the integrity of audit logs and hiding malicious activity.

Mitigations

Enforce secure transmission using TLS, implement log integrity validation (hashing/signing), and restrict log ingestion endpoints with authentication and access controls.

Title

User Identity Spoofing

Type

Spoofing

Status

High Open Mitigated

Score

Severity

TBD Low Medium High Critical

Description

An attacker attempts to impersonate a legitimate user by submitting stolen credentials or replaying authentication requests to Azure Entra ID in order to obtain a valid authentication token.

Mitigations

Enforce multi-factor authentication (MFA), implement account lockout policies, and enable identity protection with anomaly detection.

Title

Untracked Secret Access

Type

Repudiation

Status

High Open Mitigated

Score

Severity

TBD Low Medium High Critical

Description

Access to Key Vault secrets may not be fully logged, allowing malicious activity to go undetected or untraceable.

Mitigations

Enable Key Vault access logging and enforce log retention policies.

Title

Sensitive Secret Exposure

Type

Information disclosure

Status

High Open Mitigated

Score

Severity

TBD Low Medium High Critical

Description

Misconfigured access policies or compromised identities allow unauthorized access to secrets, cryptographic keys, or certificates stored in Azure Key Vault.

Mitigations

Use private endpoints, enforce RBAC, enable HSM-backed keys, and rotate secrets regularly.

Title

Service Disruption Attack

Type

Denial of service

Status

High Open Mitigated

Score

Severity

TBD Low Medium High Critical

Description

Attackers flood Azure authentication or Key Vault endpoints, causing service disruption and preventing legitimate access.

Mitigations

Enable Azure DDoS Protection, implement rate limiting, and deploy Web Application Firewall (WAF).

## 5.4 Web Application Security Scan Results

Web application HTTP security headers are a critical point of lightweight browser, defense on any web application. Instructing client browsers on transport requirements, frame and bedding and hardware API permissions. A misconfigured or security absent header or a common method of exploiting cross site scripting, mime type attacks, and sensitive data leakage.

To assess Microsoft security header posture in their public facing web application applications, the HTTP header scanner available was used to perform scan. The

*two evaluates the presence of the correct configuration on seven key security, headers and issues rating grade from A+ to F based on results.*

*The table shows a security headers evaluated in their current state, the target application to addresses threats, and the recommended configuration for full compliance.*

| <i>Microsoft</i>               | <i>Description</i>                      | <i>Suggested Mitigation</i>                                                                                                                                         |
|--------------------------------|-----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Content security policy</i> | frame-ancestors 'self'                  | Limits framing to same origin only, blocking clickjacking.<br><br>However, the active CSP is minimal, a report-only policy is in use for testing a broader ruleset. |
| <i>Strict – transmission</i>   | max-age=31536000;<br>include Subdomains | Forces browsers to use HTTPS for all future requests. The max-age of 31536000 enforces this for 1 year across all subdomains.                                       |



|                         |                                 |                                                                                                                                                                   |
|-------------------------|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>X frame option</i>   | SAMEORIGIN                      | Prevents the page from being embedded in iframes on external sites. Works alongside CSP frame-ancestors to defend against clickjacking.                           |
| <i>X-xss-protection</i> | 1; mode=block                   | Enables the XSS auditor in older browsers and blocks rendering if an attack is detected. Largely superseded by a strong Content-Security-Policy.                  |
| <i>Referrer policy</i>  | strict-origin-when-cross-origin | Controls how much referrer information is sent with requests. To limits exposure of full URLs when navigating cross-origin use 'strict-origin-when-cross-origin'. |

|                              |                                                          |                                                                                                                                                                             |
|------------------------------|----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Permission<br/>policy</i> | accelerometer=(),<br><br>camera=(),<br><br>gyroscope=(), | Prevents the browser from<br><br>MIME-sniffing the content type<br><br>forcing it to use the declared<br><br>content-type. Prevents content-<br><br>type confusion attacks. |
|------------------------------|----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### ***5.5 Top Threats Summary***

The threat modeling analysis using data flow diagrams and STRIDE based Threat Dragon report to evaluate the flow of authentication and access across several high impact risk. Focusing primarily around compromised azure Entra ID identities, escalation of privileges being the most critical point of risk. In the absence of multi-layer authentication such as MFA, older Microsoft legacy system accounts are exploited and abused to obtain valid tokens to escalate privileges inside the environment. This method of attack directly aligns in real world exploits such as Midnight Blizzard incident, demonstrating the significance and importance of enforcing strict identity governance controls.

Information disclosure is in significant risk, Azure Key Vault misconfigured policies allow overprivileged services that expose sensitive cryptographic materials, such as API key certificates and encryption keys. If keys are

stored in non-HSM back to tiers, breaking into key encrypted keys becomes an opening of attack. Attackers can gain access to these resources to compromise encryption hierarchy. Securing endpoint access and role-based access control will significantly mitigate the risk of information exposure.

Spoofing and Tampering threats exist within a process of data transmission from user to Entra ID. Attackers can attempt to intercept and replay stolen tokens to manipulate request payloads to gain an authorized access to privileged resource. Creating token validation enforcement and securing communication protocols will apply input validations, reducing the likelihood of a successful spoofing or tampering exploit.

Repudiation risk rise from insufficient, logging, and monitoring oversight. Azure Monitor allows stores audit logs to authenticate activity and instances of key vault access events. Monitoring malicious activity that otherwise may go undetected or untraceable. Centralized monitoring is available on Sentinel for real-time alerts, ensuring accountability that supports for forensic investigations.

Finally, Denial of service attacks pose a critical threat to system availability. Attackers will target authentication endpoint disrupt operations

and prevent key vault from granting legitimate access. Microsoft offers internal measures, such as Azure DDoS protection to enable rate limiting and firewall creation for web application service continuity.

Overall, the threat horizon highlights the core areas to maintain a secure cloud environment with identity, security monitoring, and access control.

## **6. System Hardening and Audit Logging**

### **6.1. Platform Chosen**

*The hardening demonstration was performed directly inside Microsoft Azure, accessed by the Azure Portal on macOS Sonoma 14.5, specifically running on a MacBook Pro 13-inch (M1, 2020) containing an Apple M1 chip and 8 GB of memory. This environment follows standard Azure best practices, consisting of a resource group (cybershield-kv) hosting the (test-api-key-test) Key Vault, a Log Analytics workspace (CyberSH-law), and diagnostic logs configured to capture Key Vault access activity in real time under an Azure for Students subscription.*

*The following system hardening will illustrate a real Azure console connected to an active Azure for Students subscription. The component being hardened is a secret stored in a role provisioned Azure Key Vault with the goal to secure secret integrity and confidentiality, actors involved are root user (myself), external user (isaacmartinez@martinezisaac), and a central monitoring and logging dashboard to ensure access and authentication flows are secure and user separation of duties and least privileges principals applied across an isolated resource group.*

### **6.2. Hardening Steps Performed**

**Step 1: Resource Group isolation**

*Access Azure console via Entra ID level account, a dedicated resource group was created (cybershield-kv) to isolate all Key Vault resources and dependences. Grouping assets allows IAM policies, diagnostic setting, and access controls are scoped only to intended resources. Terminating overly permissive system level configurations that stem from resource inheritance. These measures directly address the least privilege gap discovered in Section 3.3.*

## **Step 2: Role-Based User Assignment with Least Privilege adherence**

*Continuing to further isolate Key Vaults access, the Access control (IAM) blade role assignments were configured across four principals demonstrating separation of duties:*

- *Isaac Martinez (admin) – Owner role inherited at subscription level; Key Vault Administrator inherited from parent resource.*
- *[IsaacMartinez@MartinezIsaac.onmicrosoft](mailto:IsaacMartinez@MartinezIsaac.onmicrosoft) (externally invited user) – Granted pre-user multifactor authentication to securely access resources, along with Key Vault Reader permissions scoped to (test-secret), an accessible secret solely for this externally invited user's view.*
- *Cybershield-app (service principal) – Key Vault Secrets User inherited from parent resource.*

*This measure demonstrates granular enforcement of RBAC, with external users only granted read only metadata of one specific secret, not access to vault-wide contents, disabling*

*modification or deletion.*

Home > CyberSH-law

CyberSH-law | Logs

Log Analytics workspace

Search

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Logs

Resource visualizer

Settings

Classic

Monitoring

Automation

Help

New Query 1\*

Run

Time range: Last 24 hours

Show: 1000 results

KQL mode

```
1 AzureDiagnostics
2 | where ResourceType == "VAULTS"
3 | take 10
```

| Resource     | ResourceType | OperationName      | ResultType | CorrelationId                   | requestUri_s       |
|--------------|--------------|--------------------|------------|---------------------------------|--------------------|
| TEST-API-KEY | VAULTS       | SecretListVersions | Success    | f375ef0c-0071-4daf-9d96-2548... | https://test-api-k |
| TEST-API-KEY | VAULTS       | VaultGet           | Success    | 719dc5c5-18b2-4f52-ad0c-059f... | https://managen    |
| TEST-API-KEY | VAULTS       | VaultGet           | Success    | be8b9a94-d645-4377-8189-6e...   | https://managen    |
| TEST-API-KEY | VAULTS       | SecretList         | Success    | 1b455fec-a4f8-415c-9dd4-3c4...  | https://test-api-k |
| TEST-API-KEY | VAULTS       | VaultGet           | Success    | 43919dc4-bf32-408d-bd00-47c8... | https://managen    |
| TEST-API-KEY | VAULTS       | VaultGet           | Success    | 73077f16-ea39-4bf2-a139-85a...  | https://managen    |
| TEST-API-KEY | VAULTS       | VaultGet           | Success    | 1d37e752-5d4a-40c2-a3d1-083...  | https://managen    |
| TEST-API-KEY | VAULTS       | SecretResourceGet  | Success    | 3f468463-ef51-4166-a87a-27e8... | https://managen    |
| TEST-API-KEY | VAULTS       | VaultGet           | Success    | d252b9b8-a3df-4f9e-b3e0-100...  | https://managen    |
| TEST-API-KEY | VAULTS       | SecretGet          | Success    | 24a7eb3b-d8da-40a2-9bf1-3ad...  | https://test-api-k |

KQL output

### **Step 3: Diagnostic Setting with Read/Write/Delete Logging**

Key Vault diagnostic setting was configured to capture read, write, audit, deletion operations. The destination was set to a Log Analytics workplace (CyberSH-law) enabling a centralized log of authentication and access logs for Key Vault data plane events.

Including operations:

- GetSecret
- SecretSet
- SecretDelete

Satisfying AU controls requirements for traceability identified in Section 3.3

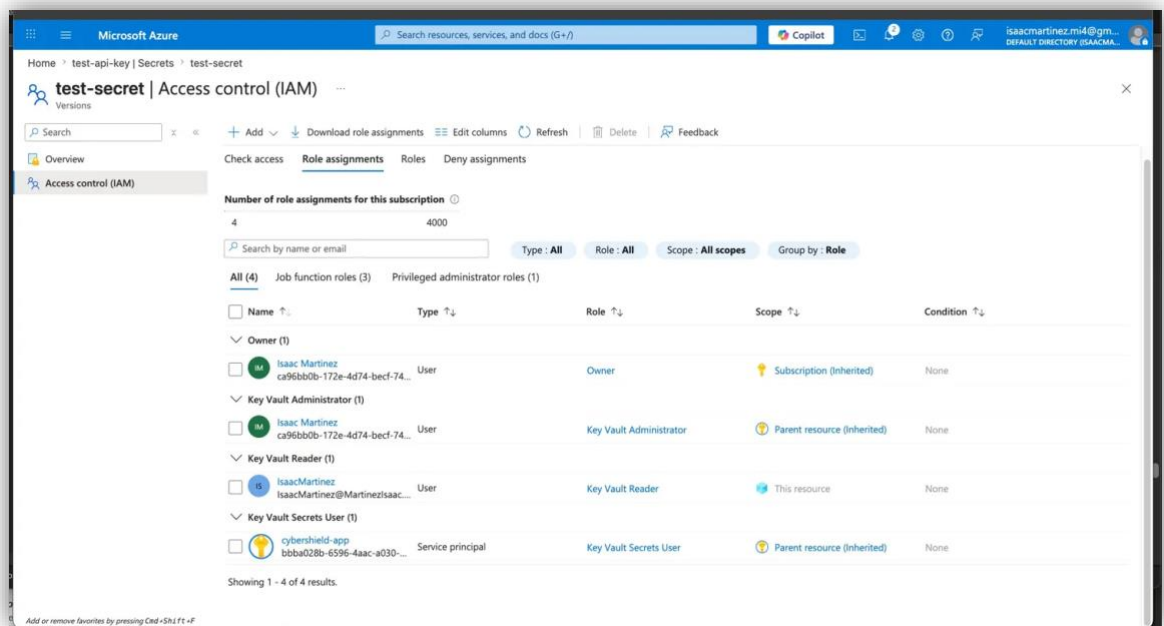
### **Step 4: Log Analytics Workspace Query Monitoring**

*Inside Log Analytics workplace (CyberSH-law) was provisioned solely for Azure Key Vault (test-api-key) and connected to Key Vault diagnostic pipeline allowing Kusto Query Language. Azure Key Vault activity was displayed by executing query (AzureDiagnostics) to filter Key Vault secret access events, allowing real time active monitoring capabilities over authenticated access patterns. Reflecting centralized monitoring posture recommend in Section 4.5.*

### **6.3. Audit Log Configuration**

The diagnostic setting on test API key vault is configured to route audit logs to (cyberSH-law) Log Analytics workspace. The configuration allows the capturing of read and deletes operations across key, secrets, and certificates, as well as all metric data. Logs blade inside workspace, display logs and using KQL queries against as your diagnostics table filtered by resource type vaults. This pipeline provides the foundation for the minimum 365-day log retention policy consisting with NSIT SP 800-171 AU control requirements.

Inside Azure IAM role assignment screen is a confirmation of four active role assignments inside the test secret resource. Then external user was successfully assigned key vault, reader scoped access with no broader permissions. The (cybershield-app) service principle holds key vault secrets users at a parent resource level. With no unauthorized role assignments privilege, escalation events, or anomaly access patterns were observed inside the confine's demonstration. The Log Analytics workplace (cyberSH-law) confirms diagnostic ingestion as active and queryable within the monitoring window.



#### Ownership Hierarchy

## 6.4. 24-Hour Monitoring Observations

During the 24-hour monitoring window, cyberSH-law Log Analytics workspace returns active diagnostic data from (test-api-key) vault via KQL query against the connect AzureDiagnostics table. The operations below are logged and all return ResultType:Success

- SecretGet: Authenticate Retrieval of secret value
- SeceretList: Enumerate available secrets without the vault
- SecertListVersion: Shows version history of secret was queried
- VaultGet: Vault metadata read operations logs
- SeceretResrouceGet: Secret resource metadata accessed

All events are attributed to Key Vault (test-api-key) resource environment within (cybershield-kv) resource group. There were no gathered failed authentication attempts, unauthorized access events, or attempts to escalate privilege during the observation window. The operations SecretGet and SeceretList confirm that the audit pipeline is capturing activity inside the data plane. Mirroring the undetected events that occurred during the Midnight Blizzard breach due to insufficient logging metrics on legacy accounts.



| ResourceProvider   | Resource     | ResourceType | OperationName      | ResultType |
|--------------------|--------------|--------------|--------------------|------------|
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | SecretListVersions | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | VaultGet           | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | VaultGet           | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | SecretResourceGet  | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | VaultGet           | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | SecretGet          | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | VaultGet           | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | VaultGet           | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | SecretList         | Success    |
| MICROSOFT.KEYVAULT | TEST-API-KEY | VAULTS       | VaultGet           | Success    |

cyberSH-law Log Analytics workspace output

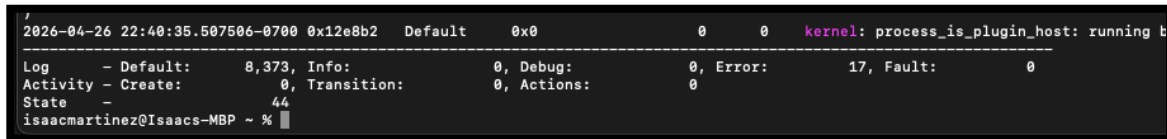
## 6.5. Security Enhancement Summary

The steps performed to harden an Azure system environment demonstrate the desired state described in section 3.2. By creating an isolated resource group and provisioning key vault with row base access control authorization demonstrates a method of how contractor tenants can enforce least privilege at a resource level rather than relying on broad subscription wide policies. Scoping secret access assignments to “this resource” instead of subscription wide reduces the radius of a compromised identity. Addressing the most common configure access configuration attacks, insider threat, and privilege escalation which was identified in section 3.3 an illustrated by the midnight blizzard breach. Requiring ID authentication for all external access law closes the authentication gap at the entry point. Collectively these steps represent the minimum viable heart and baseline for a tenant handling controlled and classified information under NSIT SP 800-171.

## 6.6. macOS Audit Logging and Disk Encryption

Endpoint-level auditing via logging can be analyzed in terms of macOS system logs. To check them, the Terminal utility and unified logging technology were applied. The following command was used to filter login events occurred during the last day:

- `log show --predicate 'eventMessage contains "login"' --last 1d`



```
/
2026-04-26 22:40:35.507506-0700 0x12e8b2 Default 0x0 0 0 kernel: process_is_plugin_host: running b
-----
Log - Default: 8,373, Info: 0, Debug: 0, Error: 17, Fault: 0
Activity - Create: 0, Transition: 0, Actions: 0
State - 44
isaacmartinez@Isaacs-MBP ~ %
```

macOS unified logging output showing login-related system events via Terminal

As a result, the logs contain information about multiple system-level actions associated with the user login, namely the activity generated by loginwindow and the kernel level as well. According to log statistics, there is a large amount of default and informational events, as well as several error and fault records. Thus, macOS consistently keeps logs of all authentication events, which is an important step towards audit traceability.

Moreover, malicious login attempts can be found based on log filtration, and unauthorized access can be detected. The centralized log collection architecture, consisting of the unified logging framework and /var/log directory in macOS, enables monitoring system actions. In order to ensure disk-level security, the FileVault encryption configuration was examined with:

- `fdsetup status`



```
isaacmartinez@Isaacs-MBP ~ % fdsetup status
FileVault is On.
```

FileVault disk encryption status confirming full-disk encryption is enabled

This technology guarantees end-to-end encryption of all endpoints and provides reliable protection against potential threats, thus meeting endpoint security requirements.

All in all, macOS logging and encryption features represent another important layer of security, besides cloud technologies used in Azure.

## 6.7. Emerging Threat Researched

Attackers using AI to conduct identity-related attacks pose the greatest danger for Microsoft's Azure environment. AI-driven generative tools allow attackers to automate credential attacks, which previously required nation-state capabilities, effectively lowering the barriers for implementing Midnight Blizzard's technique. Gartner predicts that more than 30% of organizations will consider biometric authentication unreliable on its own due to deepfakes and AI-generated identity spoofing, while preemptive cybersecurity will become 50% of IT security investment by 2030 (Gibsen, 2026). With regards to Microsoft's Entra ID environment, AI-supported threats make reconnaissance of misconfigured legacy account identities easy and automated the OAuth token stealing process implemented by Midnight Blizzard in 2024.

Contractors operating in tenant accounts should switch from push-based multifactor authentication solutions to phishing-resistant FIDO2 and WebAuthn passkey authentication solutions. Gartner predicts over 90% of multifactor authentication tokens will adopt FIDO authentication by 2027 due to industry's recognition of push notifications' vulnerability to artificial intelligence-enhanced fatigue attacks (Gibsen, 2026). Moreover, conditional access policies should include adaptive identity management capabilities to evaluate behavioral risk factors in real time. Finally, legacy authentication protocols need to be fully disabled in all tenant environments since audit results indicate that they violate current NIST and CISA phishing resistance criteria.

## 7. Summary of Recommendations

The CyberShield-360 assessment of Microsoft Corporation's Azure cloud security posture, centered on Azure Key Vault, identity and access management, and compliance with NIST SP 800-171, produced a series of findings spanning data classification, gap analysis, incident

response, threat modeling, and system hardening. The following recommendations consolidate all proposed improvements into a unified security roadmap.

### **Identity and Authentication Controls (Priority: Critical)**

The most significant and recurring finding across every section of this report is the insufficiency of identity governance and multifactor authentication enforcement. The Midnight Blizzard breach succeeded because legacy test accounts lacked MFA and operated with excessive privileges. All accounts production and non-production must be subject to mandatory MFA enforcement through Azure Active Directory Conditional Access, with phishing-resistant FIDO2 methods preferred over push-based authenticators. Legacy authentication protocols must be fully disabled across all tenant environments.

### **Hardware Security Module (HSM) Backed Key Storage (Priority: High)**

Azure Key Vault defaults to software-protected key storage tiers that do not satisfy FIPS 140-2 hardware requirements. Any contractor tenant handling Controlled Unclassified Information (CUI) must be required to provision HSM-backed keys, ensuring cryptographic material is protected at the hardware level and cannot be exported or compromised through software vulnerabilities.

### **RBAC Standardization Across Contractor Tenants (Priority: High)**

Least privilege and separation of duties enforcement is inconsistent across the contractor tenant ecosystem. Standardized RBAC templates aligned with NIST SP 800-171 AC control requirements should be deployed and enforced as a baseline configuration for all government-affiliated tenants, eliminating reliance on manual, tenant-by-tenant configurations that create compliance gaps.

### **Audit Log Retention and Centralized Monitoring (Priority: High)**

Audit log retention periods are not standardized across Azure Monitor and Microsoft Sentinel deployments. A minimum retention period of 365 days must be mandated for Key Vault access logs, authentication events, and administrative activity, satisfying NIST SP 800-171 AU control requirements and supporting forensic investigations. Microsoft Sentinel should be configured with automated alerting for anomalous authentication patterns, inactive privileged identities, and Key Vault access outside of approved hours or locations.

#### **Periodic Access Recertification (Priority: Medium)**

Key Vault access permissions should be subject to automated, periodic recertification reviews. Alerts should be triggered for identities that have not accessed Key Vault within a defined period or that hold permissions exceeding their documented role requirements. This closes the manual review gap and reduces insider threat exposure.

**Emerging Threat Preparedness (Priority: Medium)** As AI-augmented credential attacks become more prevalent, lowering the technical barrier for replicating identity-based breaches like Midnight Blizzard. Organizations must invest in behavioral anomaly detection, MFA fatigue-resistant authentication methods, and continuous legacy protocol audits. Microsoft Entra ID Protection's risk-based Conditional Access provides the technical foundation; the gap lies in enforcement consistency across contractor tenants.

In aggregate, these recommendations target the intersection of identity governance, cryptographic key management, audit accountability, and access control standardization across the four domains where Microsoft's shared responsibility model places the highest compliance burden on tenant operators. Addressing these areas in the priority order outlined in Section 3.4 will meaningfully reduce the risk of both external breaches and regulatory non-compliance across Microsoft's government contractor ecosystem.

## References

NIST. (2012, September 17). *Guide for Conducting Risk Assessments*. Csrc.nist.gov.

<https://csrc.nist.gov/pubs/sp/800/30/r1/final>

*Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment*

Process. (2007, May). SEI Digital Library. [https://www.sei.cmu.edu/library/introducing-](https://www.sei.cmu.edu/library/introducing-octave-allegro-improving-the-information-security-risk-assessment-process/)

[octave-allegro-improving-the-information-security-risk-assessment-process/](https://www.sei.cmu.edu/library/introducing-octave-allegro-improving-the-information-security-risk-assessment-process/)

msmbaldwin. (n.d.). *Azure Key Vault documentation*. Learn.microsoft.com.

<https://learn.microsoft.com/en-us/azure/key-vault/>

robmazz. (n.d.). *NIST SP 800-171 - Microsoft Compliance*. Learn.microsoft.com.

<https://learn.microsoft.com/en-us/compliance/regulatory/offering-nist-sp-800-171>

Microsoft. (2023, September 27). *Federal Risk and Authorization Management Program*

(FedRAMP) - Microsoft Compliance. Learn.microsoft.com. [https://learn.microsoft.com/en-](https://learn.microsoft.com/en-us/compliance/regulatory/offering-fedramp)

[us/compliance/regulatory/offering-fedramp](https://learn.microsoft.com/en-us/compliance/regulatory/offering-fedramp)

rmcmurray. (2026). *Regulatory Compliance details for NIST SP 800-171 R2 - Azure*

*Policy*. Microsoft.com. [https://learn.microsoft.com/en-](https://learn.microsoft.com/en-us/azure/governance/policy/samples/nist-sp-800-171-r2#configuration-management)

[us/azure/governance/policy/samples/nist-sp-800-171-r2#configuration-management](https://learn.microsoft.com/en-us/azure/governance/policy/samples/nist-sp-800-171-r2#configuration-management)

(2020, February). *Withdrawn NIST Technical Series Publication [Review of Withdrawn*

*NIST Technical Series Publication]*. *Protecting Controlled Unclassified Information in*

Nonfederal Systems. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171r2.pdf>

(2016, June 27). Kratos Completes Assessment of Microsoft's Azure Cloud Resulting in Highest FedRAMP Provisional Authority to Operate (P-ATO) [Review of Kratos Completes Assessment of Microsoft's Azure Cloud Resulting in Highest FedRAMP Provisional Authority to Operate (P-ATO)]. Acquire Media.

<https://ir.kratosdefense.com/index.php/static-files/e04844ed-c9dc-4bac-bd15-313cc89617f1>

Blink, S. (2023). Russian Hackers Stun HPE with Massive Data Theft, Exposing Employees' Personal Information. Secureblink.com. <https://www.secureblink.com/cyber-security-news/russian-hackers-stun-hpe-with-massive-data-theft-exposing-employees-personal-information>

Wright, R. (2025, February 10). HPE issues breach notifications for 2023 Midnight Blizzard attack. Cybersecurity Dive. <https://www.cybersecuritydive.com/news/hpe-issues-breach-notifications-for-2023-midnight-blizzard-attack/739674/>

(n.d.). ThreatActor\_Slides\_Midnight-Blizzard [Review of ThreatActor\_Slides\_Midnight-Blizzard]. Microsoft Security. [https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Threat-Actor\\_Slides\\_Midnight-Blizzard.pdf](https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Threat-Actor_Slides_Midnight-Blizzard.pdf)

Midnight Blizzard. (2025). Microsoft.com. <https://www.microsoft.com/en-us/security/security-insider/threat-landscape/midnight-blizzard>

AbdullahBell. (n.d.). *Azure DDoS Protection reference architectures*.

Learn.microsoft.com. <https://learn.microsoft.com/en-us/azure/ddos-protection/ddos-protection-reference-architectures>

Microsoft. (2022, August 25). *Threats - Microsoft Threat Modeling Tool - Azure*.

Learn.microsoft.com. <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>

dlepow. (2025, May 6). *Azure API Management policy reference*. Microsoft.com.

<https://learn.microsoft.com/en-us/azure/api-management/api-management-policies#access-restriction-policies>

(n.d.). *Mitigation: APIM Policy – Protect API Management from WAF Bypass with Azure Front Door* [Review of *Mitigation: APIM Policy – Protect API Management from WAF Bypass with Azure Front Door*]. SecureCloudBlog; Joosua Santasalo.

[https://azure.microsoft.com/en-us/products/monitor/?ef\\_id=\\_k\\_Cj0KCQjwv-LOBhCdARIsAM5hdKcs5NzxKTsOwxiyXz7N5AzG5PzMqi2HxSj328fcDGUUAUV5szZSo7ulaAnThEALw\\_wcB\\_k\\_&OCID=AIDcmm5edswduu\\_SEM\\_k\\_Cj0KCQjwv-LOBhCdARIsAM5hdKcs5NzxKTsOwxiyXz7N5AzG5PzMqi2HxSj328fcDGUUAUV5szZSo7ulaAnThEALw\\_wcB\\_k\\_&qad\\_source=1&qad\\_campaignid=21496728177&qbraid=0AAAAADcJh\\_thRQD8RTOkpQzhw33w0dDog&qclid=Cj0KCQjwv-LOBhCdARIsAM5hdKcs5NzxKTsOwxiyXz7N5AzG5PzMqi2HxSj328fcDGUUAUV5szZSo7ulaAnThEALw\\_wcB](https://azure.microsoft.com/en-us/products/monitor/?ef_id=_k_Cj0KCQjwv-LOBhCdARIsAM5hdKcs5NzxKTsOwxiyXz7N5AzG5PzMqi2HxSj328fcDGUUAUV5szZSo7ulaAnThEALw_wcB_k_&OCID=AIDcmm5edswduu_SEM_k_Cj0KCQjwv-LOBhCdARIsAM5hdKcs5NzxKTsOwxiyXz7N5AzG5PzMqi2HxSj328fcDGUUAUV5szZSo7ulaAnThEALw_wcB_k_&qad_source=1&qad_campaignid=21496728177&qbraid=0AAAAADcJh_thRQD8RTOkpQzhw33w0dDog&qclid=Cj0KCQjwv-LOBhCdARIsAM5hdKcs5NzxKTsOwxiyXz7N5AzG5PzMqi2HxSj328fcDGUUAUV5szZSo7ulaAnThEALw_wcB)



OWASP. (n.d.). *OWASP Threat Dragon*. Owasp.org. <https://owasp.org/www-project-threat-dragon/>

Conklin, L. (n.d.). *Threat modeling process | OWASP foundation*. Owasp.org. [https://owasp.org/www-community/Threat\\_Modeling\\_Process#data-flow-diagrams](https://owasp.org/www-community/Threat_Modeling_Process#data-flow-diagrams)

Gibsen, R. (2026, January 29). *IAM & Authentication in 2026: 5 Key Predictions for Enterprises*.

HID Global Blog. <https://blog.hidglobal.com/iam-authentication-2026-5-key-predictions-enterprises>

guywi-ms. (n.d.). *Log Analytics workspace overview - Azure Monitor*. Learn.microsoft.com. <https://learn.microsoft.com/en-us/azure/azure-monitor/logs/log-analytics-workspace-overview>

shsagir. (2024, August 12). *Kusto Query Language (KQL) overview - Kusto*. Microsoft.com. <https://learn.microsoft.com/en-us/kusto/query/?view=microsoft-fabric>